



020200

15**BNDES****Prova Discursiva****- Tarde -**BANCO NACIONAL DE DESENVOLVIMENTO ECONÔMICO E SOCIAL - BNDES
EDITAL Nº 01/2024 - SELEÇÃO PÚBLICA, DE 22 DE JULHO DE 2024**ANALISTA / Análise de Sistemas - Cibersegurança****LEIA ATENTAMENTE AS INSTRUÇÕES ABAIXO.**

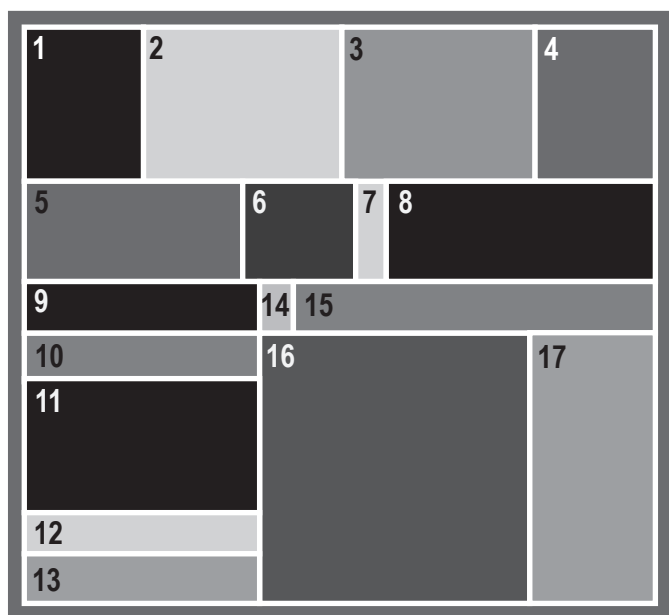
- 01** - O candidato recebeu do fiscal o seguinte material:
- a) este **Caderno de Questões**, com os enunciados das 5 (cinco) questões da Prova Discursiva, sem repetição ou falha, valendo 10,0 (dez) pontos cada questão.
 - b) 1 (um) caderno de **Folhas de Discursivas**, para o desenvolvimento das respostas às questões discursivas.
- 02** - O candidato deve verificar se este material está em ordem e se o seu nome e o seu número de inscrição conferem com os que aparecem na capa do caderno de **Folhas de Discursivas**. Caso contrário, deve notificar o fato **IMEDIATAMENTE** ao fiscal.
- 03** - Após a conferência, o candidato deverá assinar, no espaço próprio da capa do caderno de **Folhas de Discursivas**, com **caneta esferográfica transparente de tinta na cor preta**.
- 04** - As questões discursivas deverão ser respondidas, no caderno de **Folhas de Discursivas**, utilizando **caneta esferográfica transparente de tinta na cor preta**.
- 05** - O candidato deve ter muito cuidado com o caderno de **Folhas de Discursivas**, para não o **dobrar, amassar ou manchar**. O caderno de **Folhas de Discursivas** **SOMENTE** poderá ser substituído se, no ato da entrega ao candidato, já estiver danificado em suas margens superior e/ou inferior - **Barra de reconhecimento para leitura óptica**.
- 06** - **SERÁ ELIMINADO** desta Seleção Pública o candidato que:
- a) for surpreendido, durante as provas, em qualquer tipo de comunicação com outro candidato ou utilizando máquinas de calcular ou similares, livros, códigos, manuais, apostilas, impressos ou anotações;
 - b) portar ou usar, durante a realização das provas, aparelhos sonoros, fonográficos, de comunicação ou de registro, eletrônicos ou não, tais como: agendas eletrônicas e/ou similares, gravadores, *pen drive*, *mp3 player* e/ou similar, fones de ouvido, chaves com alarme ou com qualquer outro componente eletrônico, relógios de qualquer natureza, telefones celulares, microcomputadores portáteis e/ou similares;
 - c) se ausentar da sala em que se realiza a prova levando consigo o **Caderno de Questões**, e/ou o caderno de **Folhas de Discursivas**.
 - d) se recusar a entregar o **Caderno de Questões**, e/ou o caderno de **Folhas de Discursivas** quando terminar o tempo estabelecido.
 - e) **NÃO** assinar a **Lista de Presença** e/ou a capa do caderno de **Folhas de Discursivas**.
- Obs.:** O candidato só poderá se ausentar do recinto da prova após **2 (duas) horas** contadas a partir do efetivo início da mesma. Por motivos de segurança, o candidato **NÃO PODERÁ LEVAR o Caderno de Questões**, a qualquer momento.
- 07** - O tempo disponível para esta Prova Discursiva é de **4 (quatro) horas**, findo o qual o candidato deverá, obrigatoriamente, entregar o caderno de **Folhas de Discursivas** e o **Caderno de Questões**.
- 08** - Quando terminar, o candidato deverá entregar ao fiscal o **Caderno de Questões** e o caderno de **Folhas de Discursivas** e **ASSINAR a Lista de Presença**.
- 09** - As questões da Prova Discursiva estarão disponíveis, no primeiro dia útil após a realização da mesma, no endereço eletrônico da **FUNDAÇÃO CESGRANRIO** (<http://www.cesgranrio.org.br>).

QUESTÕES DISCURSIVAS

Questão nº 1

Os Objetivos de Desenvolvimento Sustentável (ODS) da Organização das Nações Unidas (ONU) se voltam a orientar a ação global para acabar com a pobreza, proteger o meio ambiente e o clima e garantir que as pessoas, em todos os lugares, possam desfrutar de paz e de prosperidade. Os 17 objetivos oferecem uma visão compartilhada de um futuro promissor e fornecem um roteiro para orientar políticas, programas e investimentos em direção a esse objetivo comum. No Brasil, a ONU está implementando 300 atividades-chave, com 188,3 milhões de dólares em recursos, em diferentes localidades, de forma a contribuir para que se atinja a Agenda 2030 no país.

Gráfico 1: Recursos Investidos pela ONU em 2024



- 1- Erradicação da pobreza 4,7% do total
- 2- Fome zero e agricultura sustentável 8% do total
- 3- Saúde e Bem-Estar 7,7% do total
- 4- Educação de qualidade 6,9% do total
- 5- Igualdade de gênero 5,4% do total
- 6- Água potável e saneamento 3% do total
- 7- Energia limpa e acessível 0,7% do total
- 8- Trabalho decente e crescimento econômico 7,9% do total
- 9- Indústria, inovação e infraestrutura 3% do total
- 10- Redução das desigualdades 2,8% do total
- 11- Cidades e comunidades sustentáveis 7,7% do total
- 12- Consumo e produção responsáveis 1,8% do total
- 13- Ação contra a mudança global do clima 3,6% do total
- 14- Vida na água 0,3% do total
- 15- Vida terrestre 5,7% do total
- 16- Paz, justiça e instituições eficazes 18,9% do total
- 17- Parcerias e meios de implementação 11,9% do total

A Agenda 2030 reconhece a indivisibilidade dos direitos humanos e a interdependência de diversas dimensões ambientais, culturais, econômicas, sociais, tecnológicas e institucionais. Por exemplo, o ODS 13 propõe adotar medidas urgentes para combater as alterações climáticas e os seus impactos, sendo intimamente relacionado ao ODS 7, que propõe garantir o acesso a fontes de energia fiáveis, sustentáveis e modernas para todos.

Entretanto, no nível global, destaca-se que o regime internacional intergovernamental primário negocia a resposta à mudança do clima, sabendo-se que as decisões políticas e vinculantes do regime acabam gerando compromissos voluntários e tendo prevalência sobre ações que idealmente deveriam ser implementadas. Muitas vezes, as ações eventualmente cuidarão de assuntos complementares, ou não cobertos em tratado obrigatório. Logo, o ODS 13, em relação ao regime multilateral, desempenha função complementar com caráter não obrigatório frente aos diversos acordos internacionais preocupados com as emissões de gases de efeito estufa.

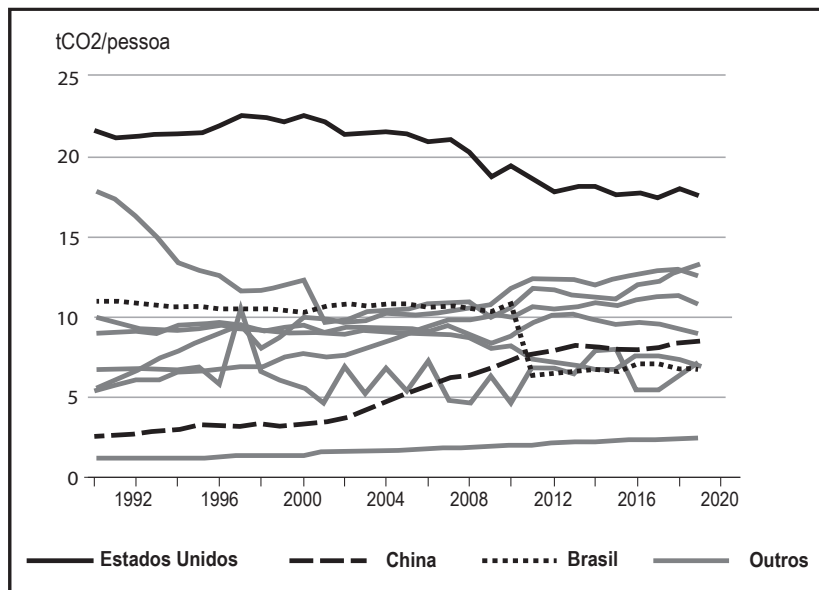
No nível dos países, dentre as formas para comparar a responsabilidade de um país pelas mudanças climáticas está o painel anual de emissões de gases de efeito estufa (GEE). Em se tratando do perfil de emissões de um país, é importante considerar a diferença entre as populações e suas contribuições dos setores econômicos para o total de emissões. No caso da China, esta ultrapassou os EUA e se tornou o maior emissor de CO₂ em 2005, em termos totais, mas não *per capita*. Isso se deve ao fato de produzir 60% da sua energia elétrica a partir de combustível fóssil, sendo a indústria a responsável por 36% das emissões de CO₂, enquanto os transportes contribuem com 8% e o setor de construção com 5%.

(Continua)

Questão nº 1 (Continuação)

O gráfico a seguir ajuda a dimensionar essa questão.

Gráfico 2: Emissões *per capita* dos 10 maiores emissores, 1990 a 2019



Fonte: Climate Watch - valores incluem emissões do setor de uso da terra e florestas.

A boa notícia é que, globalmente, as emissões *per capita* não aumentam desde 2010, um indicativo de que, aos poucos, o mundo começa a se afastar de sua trajetória de desenvolvimento anterior, intensiva em carbono. Assim, os países com as taxas de emissões *per capita* mais altas são aqueles com altas emissões nos setores de energia e uso solo. No caso do Brasil, em contraste, a redução foi resultante do aumento da parcela de fontes renováveis na matriz energética do país (principalmente a partir de usinas hidrelétricas e eólicas) e de uma diminuição significativa das taxas de desmatamento, com a implementação de políticas para proteger a Amazônia, um importante sumidouro de carbono.

Já no nível organizacional, os compromissos em relação aos ODS e às mudanças climáticas, por fim, estão relacionados aos impactos e às ações mitigadoras das organizações nos diferentes setores econômicos. Nesse sentido, o Pacto Global das Nações Unidas lançou uma força-tarefa de diretores financeiros de grandes empresas para criar um programa de dois anos, que visa colocar o setor financeiro global no centro da Agenda 2030 e seus dezessete ODS. Nesse encontro, empresas globais concordaram em dar a largada ao diálogo com líderes de empresas para que encontrem, juntos, soluções para o desenvolvimento sustentável e para a escalada nos investimentos ligados aos ODS 9 e ODS 17.

No mesmo sentido, no Brasil, o Conselho Monetário Nacional estabeleceu uma resolução que dispõe sobre a Política de Responsabilidade Social, Ambiental e Climática (PRSAC). Orientadas pela resolução, as instituições financeiras e demais instituições autorizadas a funcionar pelo Banco Central do Brasil devem estabelecer a PRSAC, uma estrutura de governança voltada à garantia de ações com vistas à sua efetividade, proporcionais ao modelo de negócio, à natureza das operações e à complexidade dos produtos, dos serviços, das atividades e dos processos da instituição; e adequadas à dimensão e à relevância da exposição ao risco social, ao risco ambiental e ao risco climático. Em relação à natureza climática, a contribuição positiva da instituição deve orientar-se na transição para uma economia de baixo carbono, em que a emissão de gases do efeito estufa é reduzida ou compensada e os mecanismos naturais de captura desses gases são preservados; e na redução dos impactos ocasionados por intempéries frequentes e severas ou por alterações ambientais de longo prazo, que possam ser associadas a mudanças em padrões climáticos.

NAÇÕES UNIDAS BRASIL. **ODS** - Sobre o nosso trabalho para alcançar os Objetivos de Desenvolvimento Sustentável no Brasil. Disponível em: <https://brasil.un.org/pt-br/sdgs#:~:text=Os%20Objetivos%20de%20Desenvolvimento%20Sustent%C3%A1vel%20s%C3%A3o%20um%20apelo%20global%20%C3%A0,de%20paz%20e%20de%20prosperidade>. Acesso em: 3 ago. 2024. Adaptado.

Considerando os cenários nos níveis global, nacional e organizacional, elabore um texto dissertativo contínuo de 20 a 25 linhas que:

- contraste os maiores e menores investimentos da ONU, em 2024, destacando a interdependência entre os ODS;
- explique as mudanças nos perfis de contribuição do Brasil, Estados Unidos da América e China quanto às emissões de GEE, nas últimas décadas;
- proponha duas ações de organizações do setor financeiro no Brasil em uma PRSAC.

(Valor: 10,0 pontos)
(Continua)

Questão nº 1 (Continuação)

RASCUNHO

Questão nº 2

De acordo com a Infraestrutura de Chaves Públicas Brasileira (ICP-Brasil, 2019), o certificado digital é um conjunto de dados de computador, gerados por uma Autoridade Certificadora, em observância à Recomendação Internacional ITU-T X.509, que se destina a registrar, de forma única, exclusiva e intransferível, a relação existente entre uma chave de criptografia e uma pessoa física, jurídica, máquina ou aplicação.

Para determinar se um certificado digital está em condição de ser utilizado no processo de validação da assinatura digital de um signatário de um documento digital, é necessário que se realizem várias etapas de verificação. Dentre essas etapas, é fundamental verificar a integridade e autenticidade do certificado digital e a sua situação (status) de revogação.

Suponha que, num certo sistema de gestão de documentos eletrônicos (GDE), o certificado digital de um signatário seja arquivado, junto com a sua assinatura digital no documento digital assinado. Sabe-se também que se encontram na base de certificados de autoridades confiáveis do GDE todos os certificados digitais que fazem parte da hierarquia de autoridades certificadoras exigida para fazer a verificação dos certificados digitais dos signatários. Todos os certificados mantidos nessa base são periodicamente verificados e considerados válidos e seguros.

Nesse contexto, com relação às etapas de verificação de um certificado digital de um signatário de documentos digitais no sistema de GDE mencionado, supondo-se que o certificado digital da autoridade certificadora, emissora do certificado digital do signatário do documento digital, seja válido e esteja presente na base de autoridades confiáveis do GDE,

- a) descreva as etapas do processo de verificação da integridade e da autenticidade do certificado digital do signatário do documento digital no sistema de GDE, sabendo que o campo Algoritmo de assinatura de todos os certificados contém o valor sha256RSA.

(Valor: 5,0 pontos)

RASCUNHO

(Continua)

Questão nº 2 (Continuação)

- b) descreva as etapas do processo de verificação da situação (status) de revogação do certificado digital do signatário do documento digital no sistema de GDE, sabendo que o campo Pontos de Distribuição da Lista de Certificados Revogados do certificado digital do signatário contém o valor URL=<http://repo.certificadora.com.br/lista.crl>.

(Valor: 5,0 pontos)

RASCUNHO

PCI Concursos

Questão nº 3

O OWASP Top 10 aponta os principais riscos de segurança encontrados em aplicações Web durante um período específico. Na publicação OWASP - 2021, a categoria de risco de injeção aparece na terceira posição do ranking, depois de vários anos na primeira posição. Mesmo assim, por causa das suas consequências nocivas para o sistema de informação, ainda é considerado um risco bastante pertinente para os dias atuais. De acordo com OWASP - 2021, “94% dos aplicativos foram testados para alguma forma de injeção, e os 33 CWEs mapeados para esta categoria têm a segunda maior ocorrência em aplicativos”.

Para minimizar os riscos de segurança da categoria de injeção, é importante adotar boas práticas de desenvolvimento de software seguro. Dentre essas práticas, é importante usar ferramentas de análise de código-fonte que possam detectar falhas de segurança antes da implantação do sistema no ambiente de produção.

Durante uma bateria de testes realizada no código-fonte de um script escrito em linguagem Python, a função `check_user_auth(conn, username, password)` foi classificada como vulnerável ao ataque de injeção SQL. Essa função recebe como argumentos um handle de comunicação com o banco de dados (`conn`), um nome de usuário (`username`) e uma senha pessoal (`password`). Sabe-se que os argumentos são previamente sanitizados, o que assegura que `conn` sempre é válido e que `username` e `password` são strings formadas por letras maiúsculas e minúsculas, dígitos numéricos, espaço em branco e caracteres de símbolos presentes na tabela ASCII.

```
import mysql.connector

def check_user_auth(conn, username, password):
    cursor = conn.cursor()
    sql_query = """SELECT * FROM users WHERE """\
        """username = '%s' AND password = '%s'"""%(username,password)
    cursor.execute(sql_query)
    user_reg = cursor.fetchall()

    if not user_reg:
        Auth_Boolean = False
    else:
        Auth_Boolean = True
    return Auth_Boolean
```

Com relação ao risco de segurança detectado na função `check_user_auth(conn, username, password)`,

- a) explique por que um adversário consegue explorar a vulnerabilidade de injeção SQL nessa função quando fornece o valor ' OR '1'='1 para ambos os argumentos `username` e `password`.

(Valor: 5,0 pontos)

(Continua)

Questão nº 3 (Continuação)

- b) explique as alterações que devem ser realizadas na atribuição da string *sql_query* e na chamada do método *cursor.execute()* para mitigar o ataque de injeção SQL realizado com a manipulação maliciosa dos argumentos *username* e *password* dessa função.

(Valor: 5,0 pontos)

RASCUNHO

Um ataque de negação de serviço (Denial of Service – DoS) é considerado bem-sucedido quando consegue provocar o impedimento do acesso autorizado a um recurso do sistema-alvo ou o retardamento das operações e funções do sistema-alvo. Quando um adversário lança uma ofensiva como essa visando o consumo de largura de banda, a técnica mais comumente adotada é a inundação (flooding) do enlace de rede do sistema-alvo, na qual a sobrecarga da rede é usada como uma forma de obstrução com a finalidade de causar uma interrupção. De acordo com Warburton, em “2024 DDoS Attack Trends”, “Após um declínio lento, mas acentuado, nos ataques DoS nos últimos anos, 2023 viu um aumento impressionante em comparação com 2022. Os ataques DDoS não só se tornaram mais prevalentes, em parte devido à sua comoditização e facilidade de uso, mas também devido às tensões globais crescentes e à facilidade com que os hacktivistas podem lançar um ataque.” Nesse contexto, segundo Yoachimik e Pacheco, em “DDoS threat report for 2023”, “Dois em cada 100 ataques DDoS de camada de rede duraram mais de uma hora e excederam 1 gigabit por segundo (gbps). Um em cada 100 ataques excedeu 1 milhão de pacotes por segundo. Além disso, a quantidade de ataques DDoS de camada de rede excedendo 100 milhões de pacotes por segundo aumentou em 15% trimestre a trimestre.” Uma variante do ataque de negação de serviço distribuído é conhecida como Distributed Reflection Denial of Service (DRDoS).

a) apresente a diferença entre o funcionamento do DDoS e o do DRDoS.

RASCUNHO

(Valor: 3,0 pontos)

Concurso RASCUNHO

RASCUNHO

PCI Concursos



020299

PCI Concursos